

Halden Distribution Ltd. — Patch and Vulnerability Management Policy

Document: P5-POL-001 · **Version:** 1.0 (draft for approval) · **Owner:** IT **Prepared by:** Muhammad Ibrahim Akmal, IT · **Date:** 2026-10-02 **Approvers:** Managing Director (policy), department heads (downtime windows) **Review cycle:** annually, or after any P0 emergency **Applies to:** all Halden servers, workstations, network devices and applications

Status: draft, unsigned. This policy is a home-lab artefact for a fictional company. It is written to be signed, and the approval block at the end is deliberately blank until a real review happens. All times below are **targets**, not measured performance.

1. Purpose

To define how Halden identifies, prioritises and remediates vulnerabilities and applies patches, so that effort goes to the risks that matter and every decision — including a decision *not* to fix something — is recorded.

2. Scope

In scope: all company-managed servers (Windows and Linux), workstations, the firewall and other network devices, and applications running on company systems.

Out of scope: personal devices not managed by IT; third-party SaaS where patching is the provider's responsibility (recorded in the vendor register, P9); anything reached only through a contract that places responsibility elsewhere.

Where scanning happens: the vulnerability scanner only ever targets Halden-managed systems on the company network. It is never pointed at a system Halden does not own or is not authorised to test.

3. Roles and responsibilities

Role	Responsibility
IT (technical)	Scan, prioritise, patch, verify, and keep the work list and dashboard current
Asset owner (business)	Approve downtime and confirm business impact for their systems
Management	Approve this policy, sign risk acceptances, and resolve conflicts over priority
All staff	Leave devices on and connected for patching windows; report problems after updates

4. The priority tiers (risk-based)

Every finding is enriched with CISA KEV status, FIRST EPSS exploit probability, asset exposure and asset criticality, and assigned a tier. ****The tier decides when the work happens; the priority score decides the order inside a tier.****

Tier	Rule	Remediation target
P0 — Emergency	Known-exploited (KEV) and internet-exposed	3 days , with a compromise check before and after patching
P1 — Critical	KEV (internal), or EPSS ≥ 0.5 on an exposed asset	7 days
P2 — High	EPSS ≥ 0.1 , or CVSS ≥ 9.0 on a criticality-3 asset	30 days
P3 — Medium	CVSS ≥ 7.0	60 days
P4 — Low	Everything else	Next maintenance cycle or upgrade

The tier rules are implemented in one place (`scripts/05-prioritize.py` , documented in `docs/00-design.md`) so that "why is this a P1?" has a single, testable answer. The model is **inspired by** the risk-tier concept in CISA BOD 26-04; it is not a claim of compliance with it.

5. Patch management

Requirement	Standard
Windows workstations	Three rings (Pilot → Broad → Servers) with deadlines; client-side targeting by Group Policy
Pilot gate	The broader rings are approved only when the pilot ring reports at least 90% installed and no incidents
Windows servers	Member servers in the Servers ring; domain controllers patched separately, DC02 then DC01 , never together
Linux servers	Automated patching, one host at a time, with pre- and post-checks; security updates covered between cycles by unattended upgrades
Drivers	Excluded from automatic approval (storage cost is not worth the risk)
Maintenance windows	Workstations: Wednesday 12:00–14:00 auto-install with a deadline. Servers: Saturday 22:00
Emergency changes	A P0 does not wait for the window; the change record is raised during the work and completed immediately after
Rollback	Every host is snapshotted before a change; every change states its backout

6. Verification and closure

1. A weekly authenticated scan runs over all managed systems.
2. Findings are prioritised and the P0/P1 items become service-desk tickets with an owner and a due date.
3. **A ticket is only closed when a re-scan no longer reports the finding.** Closing a ticket without verification is a policy breach.

1. Mean time to remediate is derived from the scan that opened the finding and the scan that closed it — never estimated.

1. A monthly report to management states open findings by tier, overdue items by tier and any KEV exposure.

7. Exceptions and risk acceptance

An exception is permitted only when all four conditions are met:

1. A **named business owner** accepts the risk in writing.
2. A **compensating control** is in place (for example, isolating the system on a restricted network segment, or restricting access to a management path).
 1. The exception has an **expiry date of no more than 90 days**, after which it is re-reviewed.
 2. The reason and the control are recorded in the exception register (`business/p05-exception-register.md`).

An expired exception that has not been re-reviewed is treated as an open finding at its original tier.

8. Records

Record	Where	Retention
Prioritised work list per scan	<code>project reports/</code>	12 months
Change records	change log (P10)	3 years
Exception register	<code>business/p05-exception-register.md</code>	3 years
Monthly vulnerability report	management pack	3 years
Vendor advisory log	<code>business/p05-vendor-advisory-log.md</code>	3 years

9. Review

This policy is reviewed annually, and immediately after any P0 emergency, any significant incident, or any change to the scanning or patching tools.

10. Approval

Role	Name	Date	Signature
Managing Director (policy approval)			
IT Manager (implementation)			
Finance Director (risk acceptance authority)			

Unsigned. This is a draft home-lab artefact. The approval rows are intentionally blank: they represent a real sign-off that has not happened, and pre-filling them would misrepresent the status.

